

ISO 27002



UNIVERSIDADE
FEDERAL DO CEARÁ
CAMPUS QUIXADÁ

Roberto Cabral

Universidade Federal do Ceará

July 11, 2025



ISO/IEC 27002: O Guia Prático dos Controles de Segurança para Auditores de SI

- A ISO/IEC 27002 é o **guia essencial** para a implementação e auditoria de controles de segurança da informação.
- Ela detalha o **COMO** proteger os ativos de informação, complementando o **O QUÊ** da ISO/IEC 27001.
- Fundamental para o auditor de SI avaliar a **eficácia e adequação** das medidas de segurança.

Introdução: O Que é a ISO/IEC 27002?

- **Definição:** A ISO/IEC 27002 é um **código de prática** que fornece diretrizes e um conjunto de controles de segurança da informação.
- **Não é Certificável:** As organizações são certificadas na ISO/IEC 27001, não na ISO/IEC 27002. A 27002 é uma norma de apoio, um guia de referência.
- **Versão Atual:** ISO/IEC 27002:2022 (publicada em fevereiro de 2022).

Relação ISO/IEC 27001 x ISO/IEC 27002: O QUÊ vs. COMO

- **ISO/IEC 27001:2022 (O QUÊ):**

- Especifica os **requisitos** para estabelecer, implementar, manter e melhorar continuamente um Sistema de Gestão da Segurança da Informação (SGSI).
- O **Anexo A** da 27001 lista os controles de segurança que *podem* ser implementados para tratar os riscos identificados.
- **Exemplo:** A 27001 exige que a organização "implemente controles de acesso" (requisito).



Relação ISO/IEC 27001 x ISO/IEC 27002: O QUÊ vs. COMO

- **Detalha** esses controles, explicando-os e fornecendo orientações sobre sua implementação.
- Ajuda a organização a escolher e aplicar os controles mais adequados.
- **Exemplo:** A 27002 detalha como implementar "controle de acesso", incluindo políticas de senhas, gestão de usuários, acessos privilegiados, etc.



Propósito da ISO/IEC 27002: Por que ela existe?

- **Fornecer Diretrizes Abrangentes:** Oferecer um conjunto de controles de segurança da informação que podem ser utilizados por qualquer organização.
- **Apoiar a ISO/IEC 27001:** Ajudar as organizações a selecionar e implementar os controles apropriados para o tratamento de riscos de segurança da informação, conforme exigido pela ISO/IEC 27001.

Propósito da ISO/IEC 27002: Por que ela existe?

- **Melhorar a Postura de Segurança:** Promover a adoção de boas práticas reconhecidas internacionalmente para proteger a confidencialidade, integridade e disponibilidade (CID) da informação.
- **Para quem é útil?:**
 - Profissionais de segurança da informação.
 - Gestores de TI.
 - **Auditores de Sistemas de Informação (ASI).**
 - Consultores de segurança.



Estrutura da ISO/IEC 27002:2022 - Visão Geral

- **Mudança Significativa:** Reorganização e atualização dos controles em relação à versão anterior (2013).
- **Número de Controles:** **93 controles** de segurança.
- **Novos Controles:** 11 novos controles foram adicionados para abordar temas atuais como inteligência de ameaças, segurança em nuvem e mascaramento de dados.

Estrutura da ISO/IEC 27002:2022 - Visão Geral

- **Categorias (Temas):** Os controles estão agrupados em 4 temas principais, facilitando a organização e a aplicação:
 - **5. Controles Organizacionais** (37 controles)
 - **6. Controles de Pessoas** (8 controles)
 - **7. Controles Físicos** (14 controles)
 - **8. Controles Tecnológicos** (34 controles)

Tema 1: Controles Organizacionais (5.x)

- **Foco:** Controles relacionados à gestão da segurança da informação em nível organizacional. Abordam políticas, papéis, responsabilidades, gestão de ativos, gestão de mudanças, etc.
- **Número de Controles:** 37 controles.
- **Exemplos de Controles :**
 - **5.1 Políticas de segurança da informação:** Definir, aprovar e revisar políticas de segurança.
 - **5.15 Controle de acesso:** Implementar regras para gerenciar o acesso a informações e ativos.
 - **5.23 Segurança da informação no uso de serviços em nuvem:** Definir e controlar a segurança na nuvem.
 - **5.7 Inteligência de ameaças:** Coletar e analisar informações sobre ameaças para proteger a organização.



Exemplo: Controle Organizacional (5.15 - Controle de Acesso)

- **Controle 5.15 (Controle de Acesso):** "As informações e outros ativos associados devem ser protegidos contra acesso não autorizado."
- **Exemplo:** A TechVendas Online deve ter regras claras sobre quem pode acessar o quê (ex: apenas o time de vendas acessa dados de clientes, desenvolvedores não acessam dados de produção).



Exemplo: Controle Organizacional (5.15 - Controle de Acesso)

- **Como o Auditor de SI Verifica:**

- **Evidência:** Solicitar a política de controle de acesso da empresa.
- **Teste:** Selecionar uma amostra de usuários e verificar suas permissões no sistema de e-commerce e no ERP. O auditor buscaria evidências de que as permissões são baseadas no "mínimo privilégio" (apenas o necessário para a função).
- **Achado Potencial:** Se um funcionário do marketing tem acesso a dados financeiros sensíveis no ERP, isso seria uma lacuna no controle.



Tema 2: Controles de Pessoas (6.x)

- **Foco:** Controles relacionados ao aspecto humano da segurança da informação. Abordam recursos humanos, conscientização, treinamento, termos e condições de emprego.
- **Número de Controles:** 8 controles.
- **Exemplos de Controles :**
 - **6.1 Triagem:** Realizar verificações de antecedentes para novos funcionários.
 - **6.3 Conscientização, educação e treinamento em segurança da informação:** Treinar funcionários sobre segurança da informação.
 - **6.8 Trabalho remoto:** Implementar controles para proteger informações em ambientes de trabalho remoto.

Exemplo: Controle de Pessoas (6.3 - Conscientização e Treinamento)

- **Controle 6.3 (Conscientização, educação e treinamento):** "Todas as pessoas relevantes devem ter conhecimento e competência adequados em segurança da informação."
- **Exemplo:** Os funcionários da TechVendas Online devem ser treinados para reconhecer ameaças como e-mails de phishing e entender a importância de senhas fortes.

Exemplo: Controle de Pessoas (6.3 - Conscientização e Treinamento)

- **Evidência:** Solicitar registros de treinamentos de segurança (listas de presença, certificados, módulos de e-learning concluídos).
- **Teste:** Aplicar um questionário ou simulação de phishing para avaliar o nível de conscientização dos funcionários.
- **Achado Potencial:** Se muitos funcionários caem em testes de phishing simulados ou não conseguem responder a perguntas básicas sobre a política de senhas, indica falha no treinamento.



Tema 3: Controles Físicos (7.x)

- **Foco:** Controles relacionados à proteção física dos ativos de informação e das instalações onde esses ativos estão localizados. Abordam segurança de áreas, equipamentos, armazenamento de mídias.
- **Número de Controles:** 14 controles.
- **Exemplos de Controles :**
 - **7.1 Segurança física de instalações:** Proteger instalações e áreas seguras contra acesso não autorizado.
 - **7.7 Mesa limpa e tela limpa:** Implementar políticas para garantir que informações sensíveis não sejam deixadas expostas.
 - **7.10 Armazenamento de mídias:** Gerenciar o armazenamento seguro de mídias (ex: fitas de backup, HDs externos).



Exemplo: Controle Físico (7.1 - Segurança Física de Instalações)

- **Controle 7.1 (Segurança física de instalações):** "Áreas seguras devem ser definidas e protegidas por perímetros de segurança e controles de entrada apropriados."
- **Exemplo:** A sala de servidores do ERP da TechVendas Online deve ter portas trancadas, controle de acesso (cartão/biometria) e talvez câmeras de vigilância.

Exemplo: Controle Físico (7.1 - Segurança Física de Instalações)

- **Evidência:** Solicitar registros de acesso à sala de servidores.
- **Teste:** Realizar uma observação física ("walkthrough") da sala de servidores, verificando se as portas estão trancadas, se há câmeras funcionando, e se pessoas não autorizadas podem entrar facilmente.
- **Achado Potencial:** Se a porta da sala de servidores está destrancada, ou se o registro de visitantes é inconsistente, indica uma falha crítica no controle físico.

Tema 4: Controles Tecnológicos (8.x)

- **Foco:** Controles relacionados à tecnologia em si. Abordam controle de acesso lógico, criptografia, segurança de rede, segurança de aplicações, backup, etc.
- **Número de Controles:** 34 controles.
- **Exemplos de Controles :**
 - **8.5 Gerenciamento de acesso privilegiado:** Restringir e monitorar acessos com altos privilégios (ex: administradores de sistema).
 - **8.12 Prevenção de vazamento de dados:** Implementar medidas para evitar a exfiltração de informações sensíveis.
 - **8.13 Backup de informações:** Realizar e testar backups para garantir a recuperação de dados.
 - **8.11 Mascaramento de dados:** Utilizar técnicas para ocultar dados sensíveis em ambientes de não produção.



Exemplo: Controle Tecnológico (8.13 - Backup de Informações)

- **Controle 8.13 (Backup de informações):** "Cópias de segurança de informações, software e sistemas devem ser mantidas e testadas regularmente de acordo com a política de backup da organização."
- **Exemplo:** A TechVendas Online deve fazer backups diários dos dados de vendas e clientes, e testar regularmente se esses backups podem ser restaurados com sucesso.



Exemplo: Controle Tecnológico (8.13 - Backup de Informações)

- **Evidência:** Solicitar logs de backup dos últimos meses.
- **Teste:** Pedir à equipe de TI para realizar um teste de restauração de um backup recente em um ambiente de teste. O auditor verificaria se os dados são restaurados integralmente, sem corrupção, e dentro do tempo estabelecido no plano de recuperação de desastres (RTO).
- **Achado Potencial:** Se o teste de restauração falha, ou se os dados restaurados estão incompletos/corrompidos, indica uma falha crítica no controle de backup.



O Papel do Auditor de SI com a ISO/IEC 27002

- **Guia de Implementação e Avaliação:** A ISO/IEC 27002 é o principal guia para o auditor entender como os controles de segurança devem ser implementados na prática.
- Ajuda a TI a entender as expectativas de segurança e o auditor a comunicar as deficiências de forma construtiva.

O Papel do Auditor de SI com a ISO/IEC 27002

- **Critério de Auditoria Detalhado:**

- Ao auditar um SGSI baseado na ISO/IEC 27001, o auditor usa a ISO/IEC 27002 para **detalhar os testes** e verificar a eficácia dos controles.
- Ex: Se a ISO 27001 exige "controle de acesso", a 27002 detalha o que isso significa (políticas, gestão de usuários, senhas, acessos privilegiados, etc.).
- **Base para Achados e Recomendações:**
- Quando um controle não está funcionando, o auditor pode referenciar a diretriz específica da ISO/IEC 27002 em seus achados.
- As recomendações de melhoria são frequentemente baseadas nas práticas descritas na 27002.

ISO/IEC 27002 na Prática da Auditoria (Exemplos)

- **Planejamento da Auditoria:**

- O auditor usa a ISO 27002 para entender os detalhes dos controles que serão avaliados, ajudando a definir os procedimentos de teste.
- **Exemplo:** Ao auditar a gestão de acessos privilegiados, o auditor consultaria o controle 8.5 (Gerenciamento de acesso privilegiado) da 27002 para saber o que procurar (políticas, logs, revisão de acessos).

ISO/IEC 27002 na Prática da Auditoria (Exemplos)

- **Execução da Auditoria (Coleta de Evidências e Testes):**
 - O auditor coleta evidências que demonstrem a implementação e a eficácia dos controles da 27002.
 - **Exemplo:** Para o controle 6.3 (Conscientização, educação e treinamento), o auditor solicitaria registros de participação em treinamentos, materiais de treinamento e aplicaria questionários para avaliar a compreensão dos funcionários.
 - **Exemplo:** Para o controle 8.12 (Prevenção de vazamento de dados), o auditor testaria a funcionalidade de uma ferramenta DLP (Data Loss Prevention) para ver se ela bloqueia o envio de dados sensíveis por e-mail ou para dispositivos USB.

ISO/IEC 27002 na Prática da Auditoria (Exemplos)

- **Relato de Achados:**

- O auditor fundamenta seus achados e recomendações nas diretrizes da ISO/IEC 27002.
- **Exemplo:** "Foi constatada uma não conformidade com o controle 7.1 (Segurança física de instalações) da ISO/IEC 27002:2022, pois a sala de servidores não possui controle de acesso por cartão e o registro de visitantes é manual e inconsistente."

A Importância da ISO/IEC 27002 para a ASI

- A ISO/IEC 27002 é o **manual de instruções do SGSI** que o auditor de SI utiliza para:
 - **Compreender** as melhores práticas de segurança.
 - **Avaliar** a implementação e a eficácia dos controles.
 - **Identificar** lacunas e vulnerabilidades.
 - **Formular** recomendações claras e baseadas em padrões.
- Ela é indispensável para garantir que as organizações não apenas declarem ter um SGSI, mas que ele seja **robusto, funcional e capaz de proteger seus ativos de informação**.

